

SPORTPHARM HQ — AZURE SETUP

For: whoever administers SportPharm's Microsoft 365 tenant and DNS. **Time:** about half a day, most of it waiting for admin consent and DNS. **Cost:** ~\$9/month (Azure Static Web Apps, Standard tier). Everything else is already paid for as part of Microsoft 365.

What this is

SportPharm HQ is an internal web app — orders to the fulfilment vendor, the team's week, marketing planning. It works today, but it is hosted as a public static site, which means three things are impossible:

1. **It is readable by anyone with the link.** No customer data or revenue figures can be put in it.
2. **There is nowhere to keep a secret,** so it cannot call the WooCommerce store or Stripe.
3. **It cannot send email as the company** — orders to the vendor currently open in Outlook for someone to press send.

Moving it to Azure Static Web Apps behind Entra ID fixes all three. The application code is already written for this, including the two Azure Functions; it needs provisioning, not development.

Who does what

The work splits cleanly by who has access:

PART	WHO	WHY
App registration, Graph permission, guest access	You	Needs Entra admin
Creating the Static Web App, linking the repo	Kennady	She owns the GitHub repo
App settings (the secrets)	You	They should not pass through anyone else
DNS records	You	HostPapa VPS
WooCommerce API key	Whoever admins the store	WordPress admin

Do not send any secret back to Kennady or paste it into a chat. Put the values straight into Azure's Configuration blade. She only needs to know when each step is done.

1 · App registration (Entra ID)

Entra ID → App registrations → New registration.

- Name: SportPharm HQ
- Supported account types: **this organizational directory only**
- Redirect URI: leave blank for now

Note the **Application (client) ID** and the **Directory (tenant) ID**. The tenant ID should be c18f5ce2-49ee-4bb9-9c5e-9ddab1991d0c — worth confirming it matches.

Certificates & secrets → New client secret. Copy the value now; it is not shown again.

API permissions → Add → Microsoft Graph → **Application permissions** → Mail.Send → **Grant admin consent**.

2 · Restrict Mail.Send — do not skip this

By default `Mail.Send` as an application permission lets this app send as **any mailbox in the tenant**. Scope it to one:

```
Connect-ExchangeOnline
New-ApplicationAccessPolicy -AppId <CLIENT_ID> `
  -PolicyScopeGroupId orders@sportpharm.com `
  -AccessRight RestrictAccess `
  -Description "SportPharm HQ may only send as the orders mailbox"
```

Verify with `Test-ApplicationAccessPolicy -Identity someone.else@sportpharm.com -AppId <CLIENT_ID>` — it should come back **denied**.

3 · Static Web App — *Kennady*

Azure → Create → Static Web App.

- **Plan: Standard.** Free does not support a custom Entra registration.
- Source: GitHub → `kennadyscott/sportpharm-content-review`, branch `main`
- Build presets: **Custom**
- App location: `/`
- Api location: `azure/api`
- Output location: leave blank

4 · Pin sign-in to this tenant

In the repo, `azure/staticwebapp.config.json` contains:

```
"openIdIssuer": "https://login.microsoftonline.com/<TENANT_ID>/v2.0"
```

Replace `<TENANT_ID>` with the real tenant ID. **This one value is what stops any Microsoft account in the world from signing in** — the default Entra provider is multi-tenant.

5 · Application settings

Static Web App → Configuration → Application settings:

NAME	VALUE
AAD_CLIENT_ID	Application (client) ID from step 1
AAD_CLIENT_SECRET	The client secret from step 1
TENANT_ID	Directory (tenant) ID
CLIENT_ID	Same as AAD_CLIENT_ID
CLIENT_SECRET	Same as AAD_CLIENT_SECRET
SEND_AS	orders@sportpharm.com
ALLOWED_TO	orders@sportpharm.com,AdminUnit@sportpharm.com
WOO_URL	https://sportpharm.com
WOO_KEY	WooCommerce consumer key — see step 7
WOO_SECRET	WooCommerce consumer secret

ALLOWED_TO is not optional. Without it, anyone who can sign in to HQ can use the company tenant to email anyone. It is the difference between a send button and an open relay.

6 · Sign-in for the other companies — read this carefully

Three companies use this app, and only one of them is on your tenant:

COMPANY	ADDRESSES	HOW THEY SIGN IN
SportPharm	@sportpharm.com	Normal work login
Enovachem	whatever they use	Guest — emailed one-time code
Pharmco	whatever they use	Guest — their own login if they have M365

Pinning the app to this tenant does not lock these people out. That is the part worth being sure about before you build it, because it reads as though it would. A B2B guest is an object *inside* the SportPharm directory — Entra issues their token from your tenant, so `openIdIssuer` pinned to your tenant is exactly right and does not need changing. The same is true of "Accounts in this organizational directory only" in step 1: guests in the directory are covered by it.

What to enable:

1. External Identities → External collaboration settings
2. Guest invite settings must allow invitations. If this is set to "No one in the organization can invite guests", nothing below works.
3. External Identities → All identity providers → **Email one-time passcode**

Enovachem has **no Microsoft tenant** — `login.microsoftonline.com` returns `AADSTS90002: Tenant not found for enovachem.com` — so the emailed code is their route. It needs nothing from their side: no tenant, no admin, no software, no licence. Guests are free at this scale.

Inviting someone: Entra ID → Users → New user → Invite external user. Their address, and nothing else required.

Do not make the app multi-tenant to solve this. It is the obvious-looking fix and it lets any Microsoft tenant on earth sign in unless the `tid` claim is also validated against an allowlist in every Function. Guests into one pinned tenant is both simpler and tighter.

A note on Pharmco: `pharmco.com` resolves to a Microsoft tenant that is *not* SportPharm's. If that tenant is genuinely Pharmco's, their people sign in with their own work credentials as guests and nothing extra is needed. If Pharmco uses a different domain, confirm which one before inviting anyone.

What the app does with this: signing in proves who someone is. What they can see is set separately, inside HQ, on its Team page — each person is assigned to a company there. A guest who has not been assigned one sees nothing at all, which is the safe direction to fail. Partner staff only ever see the orders addressed to their own company, and never drafts.

7 · WooCommerce key — *store admin*

WordPress → WooCommerce → Settings → Advanced → REST API → Add key.

- Description: SportPharm HQ
- Permissions: **Read** — read-only, deliberately. HQ only ever reads.

8 · Custom domain

Use a **subdomain**, not the apex. The apex is the live store and must not move, and apex domains on Static Web Apps need ALIAS/ANAME support the DNS host may not have.

DNS for `sportpharm.com` is on `ns1/ns2.v2640474.hostpapavps.net`. `hq.sportpharm.com` is currently unused.

1. Static Web App → Custom domains → Add → `hq.sportpharm.com`
2. Add the validation `TXT` record Azure asks for
3. Add a `CNAME` for `hq` → the app's `*.azurestaticapps.net` hostname

TLS is issued and renewed by Azure. Nothing to buy, nothing to diarise.

When you are done

Send Kennady:

- The Static Web App's URL
- Confirmation that steps 2 and 6 are done
- Nothing else — **no secrets**

She sets two values in the app's config to point it at the endpoints, and it goes live.

Afterwards

The public GitHub Pages site should be taken down and the repository set to private. Turning off Pages closes the website only; the repository history stays readable while it is public.

Questions you may reasonably have

Why not App Service or a VM? Nothing here needs one. It is static files plus two small HTTP functions, and Static Web Apps gives Entra auth, managed TLS and CI from the repo without configuration.

Why Entra rather than a password? So offboarding someone removes their HQ access at the same moment it removes their email, and so nobody manages another password list.

Can I see the code first? Yes — `azure/api/sendOrder/index.js` sends the order via Graph, `azure/api/woo/index.js` reads store totals and orders. Both are short and commented, and neither holds a credential; they read from the app settings above.